

AI-RedEye-Harness

Structure & Design

Agentic SAST harness — grounded, multi-layer, cost-aware

Author: Sam Gupta

Core principle The LLM is a **bug-theory proposer, never a source of truth**. Every finding must cite a *real* file:line, carry an explicit source→sink taint path, and survive every cheap deterministic check before it reaches an operator. Anything that fails grounding is tagged, demoted, or dropped — not reported as fact.

Key improvements vs VVAH (at a glance)

RedEye is a derivative of Visa's **Vulnerability Agentic Harness (VVAH)** (Apache-2.0), substantially reworked. The three headline gains:

Improvement	VVAH baseline	RedEye	Net effect
Fewer false positives	Agentic adversarial review only	+ voting + validator + deterministic K-of-N verifier (S8c)	More independent FP filters, several at \$0
Less hallucination	~2 deterministic checks	7-layer control (structural index, taint schema, grounding, auto-reject, PoC gate, voting, outcome verify)	Findings can't cite code that doesn't exist
Reduced cost	Agentic S1 crawl + 30-turn S6 verify	Deterministic S1b + single-pass verify + 6 free gates	≈ 44% lower \$/scan (modeled)

Highlighted up front (detailed in §9): RedEye replaces VVAH's two most expensive agentic loops (the ~40-turn attack-surface crawl and the ~30-turn, ~\$10/finding verification) with **deterministic, zero-LLM stages**, and adds five extra free gates that prune findings *before* any paid stage runs.

Pipeline phases (S1 → S9, 14 stages)

- **Discovery & Modeling** — 4 stages: S1, **S1b (DET)**, S2, S3
- **Deep Dive & Verification** — 5 stages: S4, **S4b (DET)**, **S5 (DET)**, S6, S6b
- **Synthesis, Chaining & Reporting** — 5 stages: **S7 (DET)**, S8, S8b, **S8c (DET)**, S9

Pipeline: Discovery & Modeling → Deep Dive → Verification → Synthesis → Reporting
Deterministic layers (S1b, S4b, S5, S7, S8c) carry the precision burden so the LLM stages can be aggressive about discovery.

1. Structure & Design

Three LLM phases wrapped by a deterministic harness core, with cross-cutting grounding, evidence, feedback and multi-provider layers.

Discovery & Modeling - Attack-surface map (routes / entrypoints) - Structural pre-index (DET): real routes, sources, sinks, secrets - STRIDE threat model per asset - Research strategy / lens plan

Deep Dive & Verification - Research lenses: language · crypto · logic · access-control · IaC - Grounding pass (DET): verify file:line + CWE-family tokens - Policy gate (DET): path / severity / remediation floor - Adversarial reviewer + multi-agent voting - Single-pass validator (cheap TP/FP gate)

Synthesis, Chaining & Reporting - Dedupe (DET): collapse by CWE / path / root cause - Exploit chaining - PoC gate: demand a concrete payload - Outcome verification (DET): K-of-N over 5 signals - Emit: SARIF 2.1.0 · Markdown · run manifest

Harness Core — Stage Orchestrator · Profile/Role Router · Scope & DoS limits · Structural Cache · Multi-Agent Voting · Hallucination Metrics · SARIF / MD Exporters

Grounding Layer — every finding is checked against real source before it is believed. **Evidence Store** — per-finding PASS/FAIL evidence trail + `run_manifest.json` audit record. **Feedback Loop** — SQLite TP/FP marks + baseline acceptance folded into the next scan. **Model-Agnostic Providers** — Anthropic (CLI/SDK), OpenAI, Bedrock, Vertex, Ollama, deterministic mock; per-stage budgets, no vendor lock-in.

Finding = real file:line + source→sink taint path + CWE + PoC + confidence + evidence trail + remediation

2. Stage Pipeline

Each phase groups stages; every stage card highlights its key FEATURE. Deterministic (DET) stages never call an LLM.

Discovery & Modeling

S1 Attack-Surface Mapper — *Feature*: survey entrypoints / routes into an attack-surface map. **S1b Structural Index (DET, \$0)** — *Feature*: regex/AST extracts the *real* routes, sources, sinks, secrets — ground truth for every later prompt. **S2 Threat Modeler** — *Feature*: STRIDE threat hypotheses per asset. **S3 Research Strategist** — *Feature*: plans which research lenses to fire (lens-gating).

Deep Dive & Verification

S4 Research Lenses — *Feature*: parallel lenses (language/crypto/logic/access-control/IaC); only lenses with matching sinks run. **S4b Grounding Pass (DET, \$0)** — *Feature*: opens every cited file, verifies the line range and CWE-family tokens; tags/drops hallucinations. **S5 Policy Gate (DET)** — *Feature*: drops test/vendor paths, no-remediation, below-severity-floor findings. **S6 Adversarial Reviewer + Voting** — *Feature*: challenges weak claims; N-of-M cross-vendor voting kills correlated FPs. **S6b Single-Pass Validator** — *Feature*: cheap TP/FP gate; auto-rejects S4b-tagged hallucinations with no LLM call.

Synthesis, Chaining & Reporting

S7 Deduplication (DET) — *Feature*: collapse same root cause across lenses. **S8 Exploit Strategist** — *Feature*: link findings into attack chains. **S8b PoC Gate** — *Feature*: demand a concrete exploit string; demote (or drop) findings without one. **S8c Outcome Verifier (DET, \$0)** — *Feature*: K-of-N verdict over grounding, taint, PoC, reachability, voter agreement — temperature-free. **S9 Emit** — *Feature*: deterministic SARIF 2.1.0 + Markdown + run manifest with quality metrics.

3. Overview

`redeye` is an open-source agentic SAST harness for autonomous vulnerability discovery using frontier AI models. It pairs the deep, multi-stage pipeline of an offline research harness with the operational layer of a CI/CD scanner — the same tool runs as a researcher's deep-dive on Monday and a PR gate on Tuesday.

It is **grounding-first**: deterministic scanners and checks bound what the model may claim, and the model only reasons over real, cited code. This sharply reduces hallucinations and keeps runs auditable.

Core principle. The model proposes bug *theories*; deterministic layers decide what is *believed*. A finding is promoted only when it cites a real file:line, carries an explicit source→sink taint path, and clears the verification gates. Incomplete findings are tagged, demoted, or dropped under strict mode.

4. Design Principles

- Grounding-first: the model never invents files, lines, sinks, or CWEs.
- Cheap-deterministic-first ordering: free checks run before any paid LLM call.
- Dual-mode: research deep-dive and PR/CI gate from one tool, via presets.
- Model-agnostic with no vendor lock-in; a deterministic mock is fully offline.
- Cost-aware: per-stage USD budgets, scope/DoS caps, incremental structural cache.
- Auditable: `run_manifest.json` records version, config hash, target SHA, per-stage cost and quality metrics.
- Feedback-driven: reviewer TP/FP marks and baselines calibrate the next scan.
- Safe by default: authorized targets only; findings are triage candidates, not ground truth.

5. Module Map

- `redeye/structural.py` — deterministic regex/AST pre-index (routes/sources/sinks/secrets).
- `redeye/grounding.py` — S4b grounding pass; CWE token catalogs.
- `redeye/scope.py` — file selection, diff-only PR scoping, DoS limits.
- `redeye/cache.py` — incremental structural cache keyed by (path, size, mtime).
- `redeye/baseline.py` — `.redeye-baseline.yaml` accepted-finding fingerprints.
- `redeye/schema.py` — `Finding` / taint / evidence data model.
- `redeye/pipeline/` — stage orchestrator and per-stage implementations.
- `redeye/skills/` — lens, threat-modeler, adversary, validator, PoC skills.
- `redeye/backends/` — Anthropic CLI/SDK, OpenAI, Bedrock, Vertex, Ollama, mock.
- `redeye/output/` — SARIF 2.1.0, Markdown, manifest emitters.
- `redeye/feedback/` — SQLite findings store + collect-feedback.
- `redeye/notify/` — Slack/Teams/Discord/generic webhooks (HMAC-signed).
- `redeye/config/profiles/` — default · full · cli · mock · ollama_local.

6. Stage-by-Stage Feature Highlights

S1 — Attack-Surface Mapper *Feature:* surveys entrypoints/routes and frames the attack surface for later lenses. *Produces:* attack-surface artifact. *Role:* surveyor. *Budget:* ~\$0.40.

S1b — Structural Index (deterministic) *Feature:* regex + AST extract the codebase's *real* routes, sources, sinks, and secrets before any LLM call; this inventory is the ground truth lenses must cite. **Replaces VVAH's agentic ~40-turn crawl.** *Produces:* `structural_index`. *Module:* `structural.py`. *Budget:* **\$0 (no LLM)**.

S2 — Threat Modeler *Feature:* derives STRIDE threat hypotheses per asset to focus research. *Produces:* `threat_model`. *Budget:* ~\$0.40.

S3 — Research Strategist *Feature:* plans which lenses to run; lens-gating skips CWE families with zero matching sinks/secrets. *Produces:* `research_plan`. *Budget:* ~\$0.50.

S4 — Research Lenses *Feature:* parallel lenses (language, crypto, logic, access-control, IaC) reason over the structural inventory and emit candidate findings with an explicit taint block. *Dominant cost stage.* *Produces:* candidate findings. *Budget:* ~\$6.00.

S4b — Grounding Pass (deterministic) *Feature:* resolves every cited path, checks the line is in range, and scans ± 5 lines for CWE-family tokens; outcomes tag findings grounded / hallucinated:bad-path|bad-line / weak-evidence. *Produces:* `grounding_report` + evidence rows. *Budget:* **\$0 (file I/O)**.

S5 — Policy Gate (deterministic) *Feature:* drops findings in test/vendor paths, without remediation, or below the severity floor. *Produces:* filtered set. *Budget:* ~\$0.20.

S6 — Adversarial Reviewer + Voting *Feature:* rewrites the attack chain, then N-of-M cross-vendor voting (quorum default 2) scores the refined finding; correlated FPs are voted out. *Produces:* voted findings. *Budget:* ~\$4.00.

S6b — Single-Pass Validator *Feature:* cheap (Haiku/Flash-class) TP/FP gate; auto-rejects S4b-tagged hallucinations *without* spending a token. *Produces:* validated set. *Budget:* ~\$0.50.

S7 — Deduplication (deterministic) *Feature:* collapses the same root cause reported by multiple lenses (CWE + path + skill). *Produces:* unique findings. *Budget:* ~\$0.10.

S8 — Exploit Strategist *Feature:* links findings sharing sources/sinks into multi-step attack chains. *Produces:* attack chains. *Budget:* ~\$1.50.

S8b — PoC Gate *Feature:* demands a concrete exploit string (quoted payload, URL, metachar, SQL keyword...); placeholders rejected, no-PoC findings demoted one notch (dropped under `--require-poc`). *Produces:* `poc_metrics`. *Budget:* ~\$1.00.

S8c — Outcome Verifier (deterministic) *Feature:* K-of-N verdict (threshold 3) over grounding, taint completeness, concrete PoC, reachability, and voter/validator agreement; temperature-free, so it suppresses FPs even on models that reject `temperature`. **Replaces VVAH's costly agentic verify loop.** *Produces:* verification verdict. *Budget:* **\$0 (no LLM)**.

S9 — Emit *Feature:* deterministic scoring + SARIF 2.1.0 (with taint `codeFlows`), Markdown report, and `run_manifest.json` audit record with quality metrics. *Produces:* reports + manifest. *Budget:* ~\$0.10.

7. Hallucination-Reduction Layer (7 layers)

A finding cannot reach the operator without surviving every cheap deterministic check the harness can run. Cheap layers run first.

#	Layer	Stage	What it kills	LLM cost
1	Structural pre-index	S1b	Invented routes/sources/sinks/secrets	\$0
2	Taint-flow schema	S4	Findings with no source→sink theory	\$0 (parse)
3	Grounding pass	S4b	Cited file/line that doesn't exist; no CWE tokens	\$0
4	Validator auto-reject	S6b	Findings already tagged hallucinated	\$0 (skips call)
5	PoC gate	S8b	Findings with no concrete payload	cheap
6	Multi-agent voting	S6	Findings only one voter agrees with	LLM × N
7	Outcome verifier	S8c	Findings failing the K-of-N verdict	\$0

Every survivor carries a PASS/FAIL evidence trail, and every run emits `hallucination_metrics` (`raw_lens`, `ungrounded_dropped`, `validator_rejected`, `voted_out`, `missing_poc`, `outcome_unverified`) so operators see exactly what was pruned.

8. False-Positive Suppression Rules

- No real file:line → tagged hallucinated; validator auto-rejects.
- No source + sink taint path → rejected at parse time.
- No CWE-family tokens near the cited line → confidence capped at 0.5.
- Voted out below quorum → dropped.
- No concrete PoC → demoted one severity notch (dropped under `--require-poc`).
- Fails K-of-N outcome verdict → flagged (dropped under `--require-verified`).
- In a baseline → suppressed on every future scan.
- Cross-vendor voters disagree → recorded as disagreement and pruned.

9. Improvements vs VVAH (detailed)

RedEye and VVAH share a common architecture and lineage; the differences below are RedEye's own.

9.1 Fewer false positives. VVAH relies primarily on an agentic adversarial reviewer. RedEye stacks **independent** filters: cross-vendor N-of-M voting (S6), a cheap single-pass validator (S6b), the deterministic policy gate (S5), and a deterministic **K-of-N outcome verifier (S8c)**. On temperature-rejecting models (Opus, Sonnet-4-6) voting auto-collapses for *both* tools — but RedEye keeps FP-suppression alive for **\$0** via S8c, whereas VVAH falls back on the costly agentic loop.

9.2 Less hallucination. VVAH ships ~2 deterministic checks; RedEye adds a **7-layer** control stack (S7). The structural pre-index (S1b) means lenses cite real sinks instead of inventing them, and the grounding pass (S4b) deterministically rejects any finding citing code that does not exist. Net: findings reaching the operator are source-bound by construction.

9.3 Reduced cost. RedEye replaces VVAH's two most expensive agentic loops with deterministic stages and adds more free gates:

- **Preprocess.** VVAH S1 = agentic ~40-turn crawl (\$25 cap, input compounds). RedEye S1b = AST/structural index at **\$0**.
- **Verify.** VVAH S6 = ~30-turn agentic loop, ~\$10/finding. RedEye = single-pass vote + cheap S6b validator + **\$0** S8c verifier — the biggest per-finding saving, scaling with finding count.
- **Free gates.** RedEye has 5 deterministic \$0 gates (S1b, S4b, S5, S7, S8c) plus S9 vs VVAH's two (S5, S9) — pruning before paid stages.
- **Lens-gating.** S4 skips any lens whose CWE family has zero matching sinks/secrets, so a repo with no crypto/laC never pays for those passes.

Modeled cost per scan (one ~50k-LOC repo, ~20 findings reaching verify; *illustrative, not a measured benchmark* — validate pricing and run a head-to-head before quoting):

Model (in / out \$ per 1M)	VVAH \$/scan	RedEye \$/scan	RedEye saving
Claude Opus 4.x (\$15 / \$75)	\$299	\$168	–44%
Claude Sonnet 4.x (\$3 / \$15)	\$60	\$34	–44%
OpenAI GPT-4o (\$2.50 / \$10)	\$42.50	\$23.55	–45%

Modeled token totals: RedEye ≈ **56% input / 60% output** of VVAH. The deep-dive (S4) is near parity (shared lineage); the delta comes from preprocess + verify. RedEye also emits per-stage cost in `run_manifest.json`, making an apples-to-apples benchmark straightforward.

9.4 Other improvements. Dual-mode presets (`quick/pr/ci/deep`); SARIF 2.1.0 with taint `codeFlows` for GitHub Code Scanning; PR comments with TP/FP checkboxes feeding a SQLite feedback loop; baseline acceptance; CVSS vectors; incremental structural cache; six LLM backends incl. offline mock; per-finding evidence trail and quality metrics; immutable run manifest.

10. CLI Quick Reference

- `redeye init` — interactive setup (detects creds, writes `.env`, recommends profile).
- `redeye doctor` — verify credentials + backend reachability for the active profile.
- `redeye estimate --repo PATH` — no-spend scope + cost preview.
- `redeye scan --repo PATH --preset {quick|pr|ci|deep}` — run the pipeline.
- Grounding/PoC strictness: `--strict-grounding`, `--require-poc`, `--require-verified`.
- PR mode: `--diff-only --pr-base origin/main`; DoS caps `--max-files / --max-file-bytes / --max-total-bytes; --exclude-path`.
- Feedback: `--store-findings`, `--use-feedback`, `redeye collect-feedback`.
- Baseline: `redeye baseline accept|list|remove`.
- Notify: `--webhook-url --webhook-type slack|teams|discord|generic`.

11. Reports & Outputs

- `*_report.sarif` — SARIF 2.1.0 with `security-severity` and taint `codeFlows`.
- `*_report.md` — engineer-facing detail: taint path, evidence trail, PoC, quality metrics.
- `pr-comment.md` — Markdown with TP/FP checkboxes for the feedback loop.
- `run_manifest.json` — immutable audit: version, profile, config hash, target SHA, per-stage cost + quality metrics.

12. Enterprise Readiness

- **Security:** authorized targets only; secrets referenced, never stored; findings are triage candidates.
- **Reliability:** deterministic gates, cross-vendor voting, repeatable manifest shapes; backends fall back to mock on error.
- **Scale:** diff-only PR scans, DoS caps, incremental structural cache, multi-target batch intake.
- **Governance:** per-stage budgets, hallucination/cost metrics, SQLite feedback loop, GitHub Actions workflow.